Zero Trust Network Access (ZTNA) with Zscaler: Securing User-to-Application Connectivity.

Project details

Title of the project: - Zero Trust Network Access (ZTNA) with Zscaler: Securing User-to-Application Connectivity.

Abstract:

This project proposes a Zero Trust Network Access (ZTNA) framework utilizing Zscaler Private Access (ZPA) to replace traditional VPNs and enhance cybersecurity. Unlike legacy systems that expose full networks, ZTNA ensures identity-driven, application-specific connections that keep internal applications hidden from the internet. The architecture incorporates Zscaler App Connectors, Azure AD, endpoint security tools, and SIEM platforms to implement least-privilege access, continuous monitoring, adaptive policies, and automatic access revocation. An additional resilience layer is provided through AI-Enhanced User Protection (AIUP), which leverages machine learning for behavioral analysis, producing dynamic trust scores that can mitigate risks like credential theft, phishing, and social engineering. Vulnerability assessments, such as OWASP Top 10 and Nessus scans, have identified issues like weak input validation, outdated cryptography, and XSS/SSRF attacks, with mitigation recommendations including patching, encryption, and proactive monitoring. The framework's efficacy is illustrated by real-world scenarios demonstrating its security and access management protocols. For example, unauthorized account deletion is prevented for non-admin users, resulting in an HTTP 403 status and logged attempts for accountability. Faculty can securely update grades and attendance remotely using cryptographic hashing and audit trails to ensure data integrity. In mergers, contractors receive temporary, restricted access to file servers, automatically revoked post-project. Researchers can access specific research databases with time-limited access and strict visibility restrictions. Additionally, IT administrators can connect to server management interfaces via micro-tunnels supported by real-time monitoring to prevent unauthorized lateral network movement.

Use Case Scenarios:

Scenario 1: Unauthorized Account Deletion in a Web Application

A multiuser web application has a security vulnerability whereby only administrators are intended to have the ability to delete user accounts through the endpoint /admin/delete User. However, a flaw in server-side enforcement allows any authenticated user to bypass this restriction and delete accounts by directly invoking the relevant API. This issue raises significant concerns regarding user account security and potential misuse by unauthorized users.

Output:

- Unauthorized deletion attempts are rejected with HTTP 403 Forbidden.
- Audit logs capture the attempt with user ID, timestamp, and resource targeted.

Scenario 2: Secure Access to Student Academic Records

A faculty member operating from a home office is tasked with updating grades and attendance for several courses, necessitating secure remote access to the ERP system that houses sensitive student. The comprehensive security protocols aim to safeguard sensitive student information while facilitating faculty access to necessary resources. The robust authentication and monitoring processes serve to mitigate risks associated with remote access to critical academic data.

Output:

- Attendance and grades are securely recorded in the ERP system.
- Audit logs show faculty identity, timestamps, and IP/location of login.
- Data integrity standards are maintained and verified by cryptographic hashing.

Scenario 3: Mergers and Acquisitions – Temporary Contractor Access

A contractor hired during a university system upgrade needs temporary access to a specific file server to migrate data. Using Zscaler ZPA, the contractor is granted application-specific access without being added to the university's Active Directory or given VPN credentials. The access is revoked

automatically after the project timeline.

Output:

- Contractor identity verified via separate IdP integration
- Access granted to File-Server-Migration share only
- All file transfer activities logged in Zscaler and SIEM
- Access automatically revoked after 30-day project end date

Scenario 4: External Researcher Accessing a Specific Database

An external research collaborator from another institution requires temporary access to a single research database hosted on VIT's servers. The administrator creates a time-limited, application-specific policy in Zscaler. The researcher accesses only the authorized database without any visibility into the rest of the VIT network.

Output:

- External user identity verified via temporary credentials
- Access policy enforced (Time-limited: 7 days, Application: Research-DB only)
- Database server remains hidden from internet scanners
- Session automatically terminates after policy expiry

Scenario 5: IT Administrator Performing Server Maintenance

An IT administrator needs to perform critical updates on an internal application server. Instead of connecting via VPN and gaining full network access, they use ZPA to connect directly to the specific server's management interface. The session is monitored in real-time, and any anomalous behavior (e.g., accessing unauthorized servers) is automatically terminated.

Output:

- Admin identity verified with MFA
- Direct micro-tunnel to Server-Management-Interface only
- All admin keystrokes and commands logged for audit
- Attempt to access another server automatically blocked

STAGE: 1

Title of the project: - Zero Trust Network Access (ZTNA) with Zscaler: Securing User-to-Application Connectivity.

Overview: -

The OWASP Top 10 outlines critical web application security risks that are paramount for organizations and developers to address in order to protect their systems and data. The framework identifies key vulnerabilities, starting with broken access control, which allows unauthorized users to perform actions they shouldn't be able to. It also highlights the dangers of security misconfigurations, such as utilizing default credentials or improperly exposed cloud resources, which can create significant entry points for attackers. In the realm of software supply chain security, failures associated with third-party components can introduce substantial risks alongside cryptographic failures that result from weak encryption practices. Injection flaws, notably including SQL and XSS attacks, occur due to unvalidated input, while insecure design emphasizes the importance of robust architectural principles that cannot simply be rectified post-deployment. Authentication failures represent a critical vulnerability where inadequate credentialing or the absence of multi-factor authentication allows attackers to circumvent login protocols. An ineffective logging and alerting mechanism can delay breach detection, revealing the importance of maintaining vigilant monitoring systems. Lastly, the mishandling of exceptional conditions through poor error handling can expose sensitive information, leaving systems vulnerable. To effectively mitigate these vulnerabilities, the OWASP Top 10 recommends that developers and organizations enforce proper access controls, implement stringent input validation, maintain secure configurations, adopt cryptographic best practices, ensure robust authentication mechanisms, and develop comprehensive logging systems, alongside secure design principles. Collectively, these strategies form a foundational defense that not only seeks to prevent breaches but also enhances the capability to

detect and respond to the most prevalent threats in contemporary web applications.

List of teammates –

S.no	name	collage	contact
1	JAIPHIRANESH S	KPR College of Arts Science and Research	23bai016@kprcas.ac.in
2	NITHISH VENKATACHALAM	KPR College of Arts Science and Research	23bai032@kprcas.ac.in
3	NIDHEESH N	KPR College of Arts Science and Research	23bai031@kprcas.ac.in
4	SADHANA Y R	KPR College of Arts Science and Research	23bai044@kprcas.ac.in
5	AFREED SHERIFF R	KPR College of Arts Science and Research	23bai001@kprcas.ac.in

List of Vulnerability Table –

S.no	Category Name	Vulnerability Name	CWE/CVE - No
1	Broken Access Control	Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')	CWE-22
2	Security Misconfiguration	ASP.NET Misconfiguration: Creating Debug Binary	CWE-11
3	Software Supply Chain Failures	Unimplemented or Unsupported Feature in UI	CWE-447
4	Cryptographic Failures	Weak Encoding for Password	CWE-261
5	Injection	Improper Input Validation	CWE-20
6	Insecure Design	External Control of File Name or Path	CWE-73
7	Authentication Failures	Improper Authentication	CWE-287
8	Software or Data Integrity Failures	Untrusted Search Path	CWE-426
9	Security Logging & Alerting Failures	Improper Output Neutralization for Logs	CWE-117
10	Mishandling of Exceptional Conditions	Divide By Zero	CWE-3369

REPORT: -1

Vulnerability Name: - Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')

CWE/CVE: - CWE-22

OWASP/SANS Category: - A01:2025 Broken Access Control

Description: - This vulnerability occurs when an application uses external input to construct a file path without properly sanitizing or validating it. Attackers can manipulate the input to include special characters or sequences like "../" to navigate outside the intended directory and access sensitive files or directories elsewhere in the system. This can lead to unauthorized access, information disclosure, or even code execution. The vulnerability encompasses both relative path traversal (using "../") and absolute path traversal (using absolute paths like "/usr/local/bin").

Business Impact: - The business impact of a path traversal vulnerability can be significant. Attackers could potentially read sensitive files, including configuration files, source code, or data files, leading to data breaches and intellectual property theft. They might also be able to overwrite critical system files or inject malicious code, resulting in system compromise, denial of service, or even complete takeover of the affected system. This can lead to financial losses, reputational damage, legal liabilities, and loss of customer trust.

Identifier	CISA Kev Info	Published Date	CNA	Description
CVE-2025-5741	✕	2025-06-10	Schneider Electric SE	CWE-22: Improper Limitation of a Pathname to a Restricted Directory ("Path Traversal") vulnerability exists that could cause arbitrary file reads from the charging station. The exploitation of this vulnerability does require an authenticated session or web server.
CVE-2025-5740	✕	2025-06-10	Schneider Electric SE	CWE-22: Improper Limitation of a Pathname to a Restricted Directory ("Path Traversal") vulnerability exists that could causse arbitrary file writes when an authenticated user on the web server manipulates file path.
CVE-2025-54927	✕	2025-08-20	Schneider Electric SE	CWE-22: Improper Limitation of a Pathname to a Restricted Directory ("Path Traversal") vulnerability exists that could cause unauthorized access to sensitive files when an authenticated attackers uses a crafted path input that is processed by the system.
CVE-2025-54926	✕	2025-08-20	Schneider Electric SE	CWE-22: Improper Limitation of a Pathname to a Restricted Directory ("Path Traversal") vulnerability exists that could cause remote code execution when an authenticated attacker with admin privileges uploads a malicious file over HTTP which then gets executed.

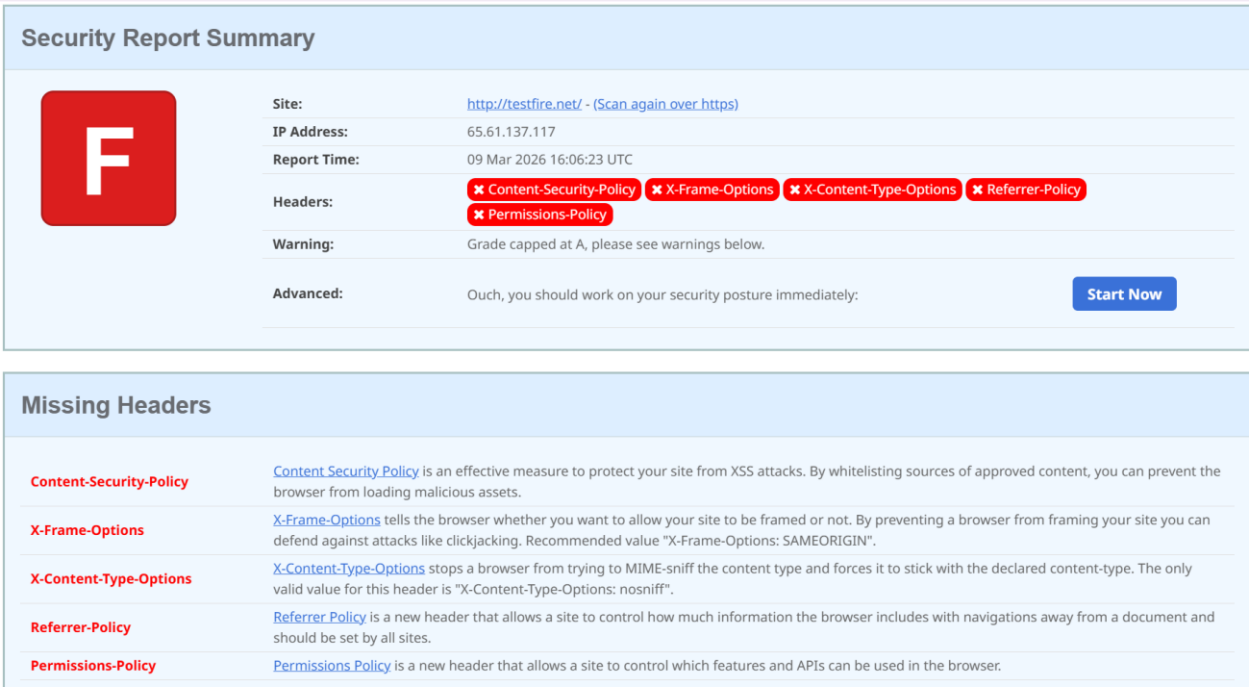
2.Vulnerability Name: - ASP.NET Misconfiguration: Creating Debug Binary

CWE/CVE: - CWE-11

OWASP/SANS Category: - A02:2025 Security Misconfiguration

Description: - This describes a security vulnerability where applications compiled with debugging enabled are deployed to production environments. Debug binaries expose detailed debugging messages that can be leveraged by attackers to gain information about the system and plan attacks. Debug binaries should only be used in development and testing environments.

Business Impact: - Exposure of debugging messages in a production ASP .NET application can provide attackers with valuable information about the system's internal workings. This information can be leveraged to identify vulnerabilities, understand the application's logic, and plan targeted attacks. Successful exploitation of these vulnerabilities can lead to data breaches, service disruptions, financial losses, and reputational damage. The use of debug binaries in production environments increases the attack surface and the potential for successful attacks, negatively impacting the organization's security posture and business operations.



Security Report Summary

F

Site:	http://testfire.net/ - (Scan again over https)
IP Address:	65.61.137.117
Report Time:	09 Mar 2026 16:06:23 UTC
Headers:	✖ Content-Security-Policy ✖ X-Frame-Options ✖ X-Content-Type-Options ✖ Referrer-Policy ✖ Permissions-Policy
Warning:	Grade capped at A, please see warnings below.
Advanced:	Ouch, you should work on your security posture immediately: Start Now

Missing Headers

Content-Security-Policy	Content Security Policy is an effective measure to protect your site from XSS attacks. By whitelisting sources of approved content, you can prevent the browser from loading malicious assets.
X-Frame-Options	X-Frame-Options tells the browser whether you want to allow your site to be framed or not. By preventing a browser from framing your site you can defend against attacks like clickjacking. Recommended value "X-Frame-Options: SAMEORIGIN".
X-Content-Type-Options	X-Content-Type-Options stops a browser from trying to MIME-sniff the content type and forces it to stick with the declared content-type. The only valid value for this header is "X-Content-Type-Options: nosniff".
Referrer-Policy	Referrer Policy is a new header that allows a site to control how much information the browser includes with navigations away from a document and should be set by all sites.
Permissions-Policy	Permissions Policy is a new header that allows a site to control which features and APIs can be used in the browser.

3.Vulnerability Name: - Unimplemented or Unsupported Feature in UI

CWE/CVE: - CWE-447

OWASP/SANS Category: - A03:2025 Software Supply Chain Failures

Description: - A UI function for a security feature appears to be supported and gives feedback to the user that suggests that it is supported, but the underlying functionality is not implemented.

Business Impact: **-** Failure to implement a security feature in the UI, despite the UI indicating otherwise, can lead to a false sense of security for the user. This can result in users making decisions or taking actions that expose the system or their data to risk, believing they are protected when they are not. The business impact includes potential data breaches, financial losses, reputational damage, and legal liabilities. The severity depends on the criticality of the unimplemented security feature and the sensitivity of the data or systems it was intended to protect.

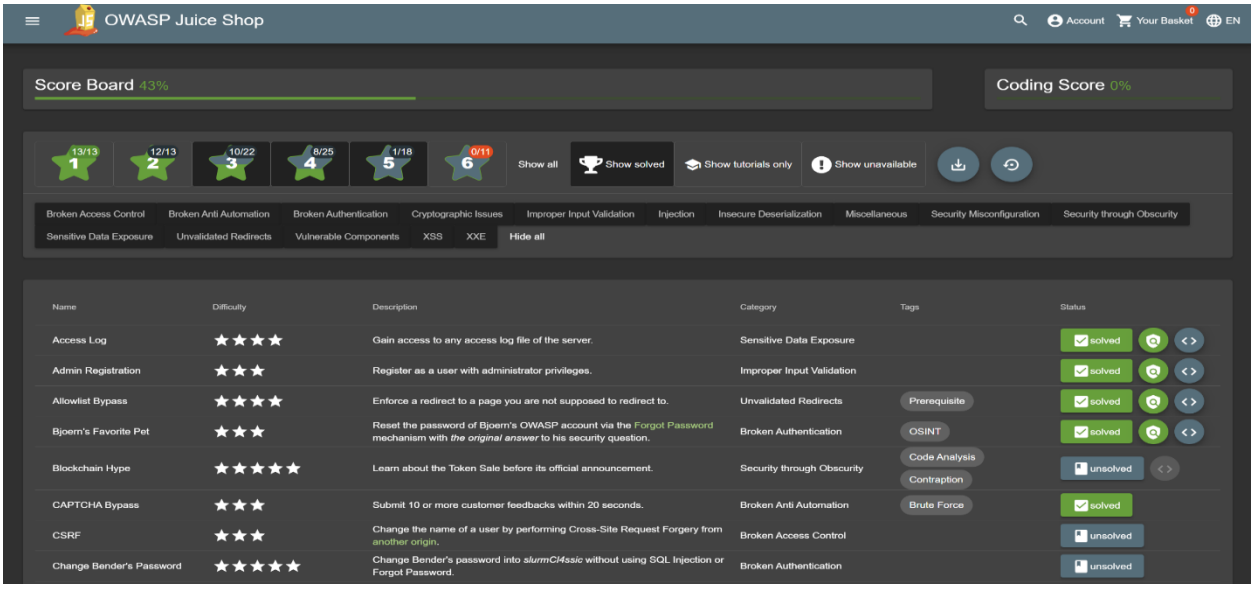
CWE-447: Unimplemented or Unsupported Feature in UI

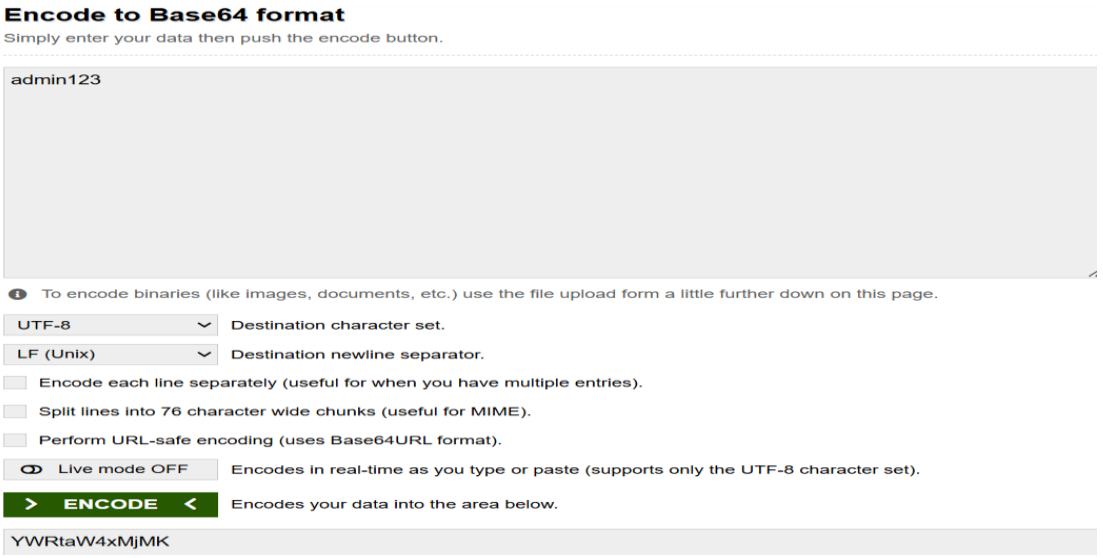
Weakness ID: 447
Vulnerability Mapping: ALLOWED
Abstraction: Base

View customized information: Conceptual | Operational | Mapping Friendly | **Complete** | Custom

Description

A UI function for a security feature appears to be supported and gives feedback to the user that suggests that it is supported, but the underlying functionality is not implemented.





4.Vulnerability Name: - Weak Encoding for Password

CWE/CVE: - CWE-261

OWASP/SANS Category: - A04:2025 Cryptographic Failures

Description: - Password management issues occur when a password is stored in plaintext in an application's properties or configuration file. A programmer can attempt to remedy the password management problem by obscuring the password with an encoding function, such as base 64 encoding, but this effort does not adequately protect the password.

Business Impact: - The business impact of storing passwords in plaintext or using weak encoding like Base64 is significant. If attackers gain access to the application's properties or configuration files, they can easily retrieve the passwords. This can lead to:

- **Data breaches:** Attackers can use the compromised passwords to access sensitive data, leading to financial losses, reputational damage, and legal liabilities.
- **Unauthorized access:** Attackers can gain unauthorized access to critical systems and resources, potentially disrupting operations and causing further damage.

5.Vulnerability Name: - Improper Input Validation

CWE/CVE: - CWE-20

OWASP/SANS Category: - A05:2025 Injection

Description: - Input validation is a frequently-used technique for checking potentially dangerous inputs in order to ensure that the inputs are safe for processing within the code, or when communicating with other components.

Input can consist of:

- raw data - strings, numbers, parameters, file contents, etc.
- metadata - information about the raw data, such as headers or size

Data can be simple or structured. Structured data can be composed of many nested layers, composed of combinations of metadata and raw data, with other simple or structured data.

Many properties of raw data or metadata may need to be validated upon entry into the code, such as:

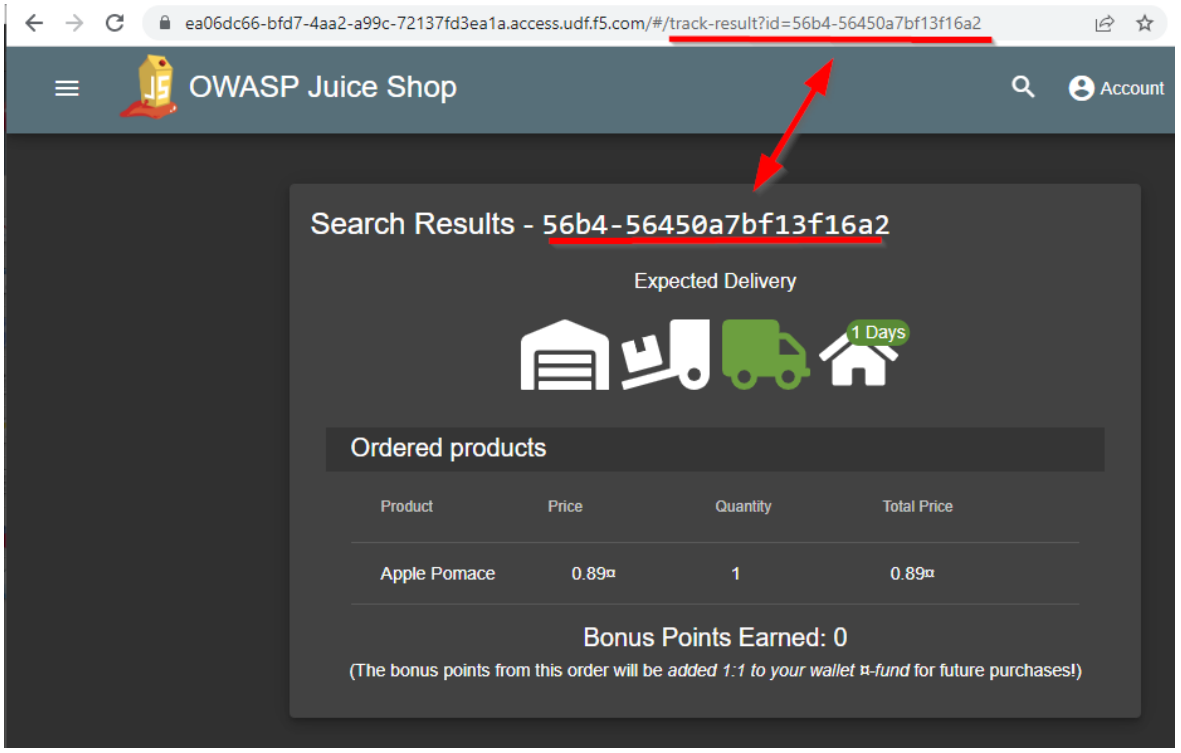
- specified quantities such as size, length, frequency, price, rate, number of operations, time, etc.
- implied or derived quantities, such as the actual size of a file instead of a specified size
- indexes, offsets, or positions into more complex data structures
- symbolic keys or other elements into hash tables, associative arrays, etc.
- well-formedness, i.e. syntactic correctness - compliance with expected syntax
- lexical token correctness - compliance with rules for what is treated as a token
- specified or derived type - the actual type of the input (or what the input appears to be)
- consistency - between individual data elements, between raw data and metadata, between references, etc.
- conformance to domain-specific rules, e.g. business logic
- equivalence - ensuring that equivalent inputs are treated the same
- authenticity, ownership, or other attestations about the input, e.g. a cryptographic signature to prove the source of the data

Implied or derived properties of data must often be calculated or inferred by the code itself. Errors in deriving properties may be considered a contributing factor to improper input validation.

Business Impact: - The absence of proper input validation can lead to several business

impacts:

- **Security Vulnerabilities**: Failure to validate inputs can create vulnerabilities such as SQL injection, cross-site scripting (XSS), and buffer overflows. Exploiting these vulnerabilities can lead to data breaches, loss of sensitive information, reputational damage, financial losses, and legal liabilities.
- **System Instability and Downtime**: Invalid inputs can cause applications and systems to crash, leading to downtime and disruption of services. This can result in lost revenue, decreased productivity, and customer dissatisfaction.
- **Data Corruption**: Improperly validated data can corrupt databases and other data stores, leading to inaccurate reporting, flawed decision-making, and inconsistencies across systems. Data corruption can also lead to compliance issues and regulatory penalties.
- **Compliance Violations**: Many regulations (e.g., GDPR, HIPAA, PCI DSS) require organizations to protect sensitive data and ensure data integrity. Lack of input validation can result in non-compliance, leading to fines, legal action, and loss of business.
- **Increased Development and Maintenance Costs**: Addressing vulnerabilities caused by poor input validation often requires costly code reviews, security audits, and remediation efforts. It also increases the complexity of software development and maintenance.



6.Vulnerability Name: - External Control of File Name or Path

CWE/CVE: - CWE-73

OWASP/SANS Category: - A06:2025 Insecure Design

Description: - This could allow an attacker to access or modify system files or other files that are critical to the application.

Path manipulation errors occur when the following two conditions are met:

1. An attacker can specify a path used in an operation on the filesystem.

2. By specifying the resource, the attacker gains a capability that would not otherwise be permitted.

For example, the program may give the attacker the ability to overwrite the specified file or run with a configuration controlled by the attacker.

Business Impact: -

- Data breach and downtime from access/overwrite of critical files.
- Privilege escalation via config or system files.
- Denial of service and reputation damage.
- Potential for injected malware and bypassed security checks.

Overall, path manipulation is a high-risk security issue.

403 Forbidden

CVE-2022-45918	Chain: a learning management tool debugger uses external input to locate previous session logs (CWE-73) and does not properly validate the given path (CWE-20), allowing for filesystem path traversal using "../" sequences (CWE-24)
CVE-2008-5748	Chain: external control of values for user's desired language and theme enables path traversal.
CVE-2008-5764	Chain: external control of user's target language enables remote file inclusion.

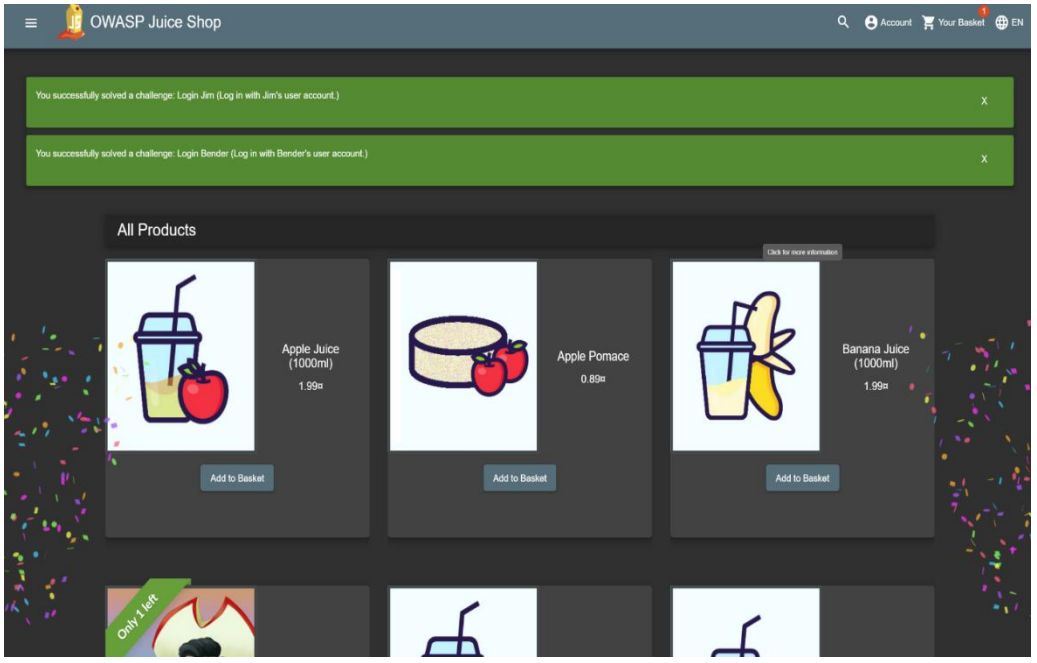
7.Vulnerability Name: - Improper Authentication

CWE/CVE: - CWE-287

OWASP/SANS Category: - A07:2025 Authentication Failures

Description: - When an actor claims to have a given identity, the product does not prove or insufficiently proves that the claim is correct.

Business Impact: - Improper authentication undermines the entire security posture of an organization, making it vulnerable to both external cyberattacks and insider threats, with cascading effects on trust, compliance, and business continuity.



8.Vulnerability Name: - Untrusted Search Path

CWE/CVE: - CWE-426

OWASP/SANS Category: - A08:2025 Software or Data Integrity Failures

Description: - This might allow attackers to execute their own programs, access unauthorized data files, or modify configuration in unexpected ways. If the product uses a search path to locate critical resources such as programs, then an attacker could modify that search path to point to a malicious program, which the targeted product would then execute. The problem extends to any type of critical resource that the product trusts.

Business Impact: - The business impact of an untrusted search path vulnerability can be severe.

Attackers exploiting this vulnerability can execute arbitrary code, potentially leading to:

- **Data breaches:** Unauthorized access to sensitive data files.
- **System compromise:** Modification of critical configurations, allowing attackers to take control of the system.
- **Malware installation:** Introduction of malicious programs that can further compromise the system and spread to other systems.
- **Denial of service:** Disruption of services due to malicious code execution or system compromise.

9.Vulnerability Name: - Improper Output Neutralization for Logs

CWE/CVE: - CWE117

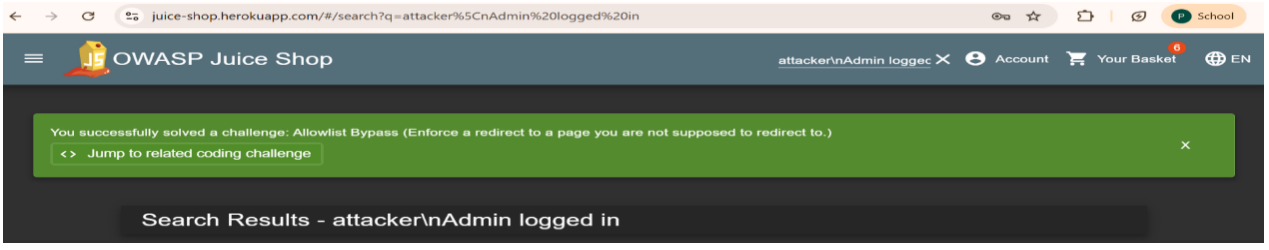
OWASP/SANS Category: - A09:2025 Security Logging & Alerting Failures

Description: - The product constructs a log message from external input, but it does not neutralize or incorrectly neutralizes special elements when the message is written to a log file.

```
C:\Users\PREETHI>set PATH
Path=C:\Python313\Scripts\;C:\Python313\;C:\Python312\Scripts\;C:\Python312\;C:\ProgramData\Oracle\Java\javapath;C:\WIND
OWS\system32;C:\WINDOWS;C:\WINDOWS\System32\Wbem;C:\WINDOWS\System32\WindowsPowerShell\v1.0\;C:\WINDOWS\System32\OpenSSH
\;D:\flutter;D:\flutter\bin;D:\cmdline-tools;D:\cmdline-tools\bin;D:\jdk-22.0.2;D:\jdk-22.0.2\bin;C:\ProgramData\chocola
tey\bin;D:\flutter\bin\cache\dart-sdk;D:\flutter\bin\cache\dart-sdk\bin;C:\Program Files\nodejs\;C:\Users\new user\AppDa
ta\Roaming\npm;C:\Users\new user\AppData\Roaming\npm\node_modules\firebase-tools;C:\Users\PREETHI\AppData\Local\Microsof
t\WindowsApps;C:\Users\PREETHI\AppData\Roaming\npm;C:\Users\PREETHI\AppData\Local\Programs\Microsoft VS Code\bin;C:\User
s\new user\AppData\Roaming\npm;C:\Users\new user\AppData\Roaming\npm\node_modules\firebase-tools;C:\Program Files\sf\bin
PATHEXT=.COM;.EXE;.BAT;.CMD;.VBS;.VBE;.JS;.JSE;.WSF;.WSH;.MSC;.PY;.PYW
```

Business Impact: - The business impact of a product constructing a log message from external input without neutralizing special elements, leading to vulnerabilities when written to a log file, can be significant. This is primarily due to the risk of log injection attacks. Attackers can manipulate log data to inject malicious code or commands.

Identifier	CISA Kev Info	Published Date	CNA	Description
CVE-2020-7490	✖	2020-04-22	Schneider Electric SE	A CWE-426: Untrusted Search Path vulnerability exists in Vijeo Designer Basic (V1.1 HotFix 15 and prior) and Vijeo Designer (V6.9 SP9 and prior), which could cause arbitrary code execution on the system running Vijeo Basic when a malicious DLL library is loaded by the Product.
CVE-2020-7476	✖	2020-03-23	Schneider Electric SE	A CWE-426: Untrusted Search Path vulnerability exists in ZigBee Installation Kit (Versions prior to 1.0.1), which could cause execution of malicious code when a malicious file is put in the search path.
CVE-2019-6826	✖	2019-09-17	Schneider Electric SE	A CWE-426: Untrusted Search Path vulnerability exists in SoMachine HVAC v2.4.1 and earlier versions, which could cause arbitrary code execution on the system running SoMachine HVAC when a malicious DLL library is loaded by the product.



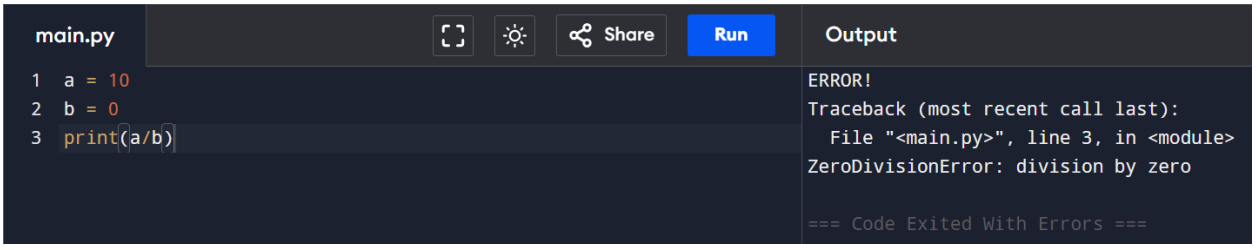
10.Vulnerability Name: - Divide By Zero

CWE/CVE: - CWE-369

OWASP/SANS Category: - A10:2025 Mishandling of Exceptional Conditions

Description: - This weakness typically occurs when an unexpected value is provided to the product, or if an error occurs that is not properly detected. It frequently occurs in calculations involving physical dimensions such as size, length, width, and height.

Business Impact: - The most significant business impact of a CWE-369 vulnerability (Divide By Zero) is a denial-of-service (DoS) condition, potentially leading to a crash, exit, or restart of the affected system. This impacts availability



Stage 2

Overview: -

Nessus is a vulnerability scanner developed by Tenable, Inc. It is a remote scanner, meaning that it does not need to be installed on the target host to scan it. Nessus works by sending a variety of probes to the target host in order to identify vulnerabilities. These probes can include network traffic, operating system commands, and application requests.

Nessus uses a plugin-based architecture. Plugins are small pieces of code that are designed to identify specific vulnerabilities. There are over 1200 plugins available for Nessus, covering a wide range of vulnerabilities in operating systems, applications, and network devices.

When Nessus scans a host, it first uses a discovery plugin to identify the operating system and services running on the host. Once the host has been discovered, Nessus runs a series of plugins to test for vulnerabilities. For each vulnerability that Nessus finds, it provides a detailed report that includes the severity of the vulnerability, the

steps to reproduce the vulnerability, and the steps to remediate the vulnerability.

Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications. It can also be used to scan specific ports and services. Nessus can be configured to run scans on a schedule or manually.

Here is a step-by-step explanation of how Nessus works:

1. Nessus connects to the target host using a variety of protocols, including TCP, UDP, and ICMP.

2. Nessus sends a series of probes to the target host in order to identify its operating system and services.
3. Nessus runs a series of plugins to test for vulnerabilities.

Nessus generates a report that includes the severity of each vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability. Comprehensive vulnerability coverage: Nessus has over 1200 plugins available, covering a wide range of vulnerabilities in operating systems, applications, and network devices.

Easy to use: Nessus has a user-friendly interface that makes it easy to configure and run scans.

Comprehensive reporting: Nessus provides detailed reports that include the severity of each vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.

Scalability: Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications.

Flexibility: Nessus can be configured to run scans on a schedule or manually.

Nessus is a valuable tool for security professionals who need to identify and remediate vulnerabilities in their networks. It is easy to use and provides comprehensive reports that can be used to prioritise remediation efforts.

Here are some of the benefits of using Nessus:

Nessus is a powerful tool that can be used to improve the security of any network. It is

a valuable asset for any security professional.

Target website- http://testfire.net/

Target ip address: - 65.61.137.117

List of vulnerability

S.no	Vulnerability name	Severity	plugins
1	TLS Version 1.0 Protocol Detection	Medium	104743
2	SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)	Low	83875
3	HTTP Server Type and Version	Info	10107
4	SSL Certificate Information	Info	10863
5	SSL/TLS Recommended Cipher Suites	Info	156899
6	Service Detection	Info	22964
7	Apache Tomcat Detection	Info	39446
8	Nessus SYN scanner	Info	11219
9	Common Platform Enumeration (CPE)	Info	45590
10	Nessus Scan Information	Info	19506

REPORT: -

1.Vulnerability Name: - TLS Version 1.0 Protocol Detection

Severity: - Medium

Plugin: - 104743

Port: - 433

Description: - The remote service accepts connections encrypted using TLS 1.0. TLS 1.0 has a number of cryptographic design flaws. Modern implementations of TLS 1.0 mitigate these problems, but newer versions of TLS like 1.2 and 1.3 are designed against these flaws and should be used whenever possible.

As of March 31, 2020, Endpoints that aren't enabled for TLS 1.2 and higher will no longer function properly with major web browsers and major vendors.

PCI DSS v3.2 requires that TLS 1.0 be disabled entirely by June 30, 2018, except for POS POI terminals (and the SSL/TLS termination points to which they connect) that can be verified as not being susceptible to any known exploits.

Solution: - Enable support for TLS 1.2 and 1.3, and disable support for TLS 1.0.

Business Impact: -Continued use of TLS 1.0's encryption, known for its inherent cryptographic flaws, exposes the organization to heightened security risks, increasing the likelihood of data breaches and cyberattacks. This vulnerability jeopardizes compliance with industry standards, specifically PCI DSS v3.2, which mandates the complete cessation of TLS 1.0 use. Non- compliance risks regulatory penalties and erodes customer trust. Moreover, endpoints that lack support for TLS 1.2 and higher will experience impaired functionality with major web browsers and vendors, potentially leading to lost business opportunities and damage to the organization's

reputation. Addressing this vulnerability is imperative to mitigate these multifaceted risks and maintain a secure and trustworthy online presence.

2.Vulnerability Name: - 83875 - SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)

Severity: - Low

Plugin: - 83875

Port: - 443

Description: - The remote host allows SSL/TLS connections with one or more Diffie-Hellman moduli less than or equal to 1024 bits. Through cryptanalysis, a third party may be able to find the shared secret in a short amount of time (depending on modulus size and attacker resources). This may allow an attacker to recover the plaintext or potentially violate the integrity of connections.

Solution: - Reconfigure the service to use a unique Diffie-Hellman moduli of 2048 bits or greater.

Business Impact: - Allowing SSL/TLS connections with weak Diffie-Hellman moduli raises security concerns. An attacker with sufficient resources and computing power could compromise the shared secret relatively quickly, potentially leading to the decryption of sensitive data or the violation of connection integrity. While the severity is low, the risk of data breaches and integrity compromise should not be underestimated, and it is essential to address this vulnerability to maintain data security and user trust.

3.Vulnerability Name: - 10107 - HTTP Server Type and Version

Severity: - INFO

Plugin: - 10107

Port: - 443

Description: - This plugin attempts to determine the type and the version of the remote web server.

Solution: - N/A

Business Impact: -This relates to the identification of the remote web server's type and version. While this issue doesn't pose an immediate security threat, it can provide valuable information to potential attackers about the server's software stack. Knowledge of the server type and version may aid attackers in exploiting known vulnerabilities specific to that software, making it important to restrict such information from being easily accessible to enhance the server's overall security posture.

4.Vulnerability Name: - SSL Certificate Information

Severity: - Info

Plugin: - 10863

Port: - 443

Description: - This plugin connects to every SSL-related port and attempts to extract and dump the X.509 certificate.

Solution: - N/A

Business Impact: - Certificates are critical for secure communication. If expired, misconfigured, or issued by an untrusted CA, users may see warnings, damage trust and potentially violating compliance requirements (e.g., PCI DSS, HIPAA). Certificates also reveal metadata (like organization, location) that could be leveraged in reconnaissance by attackers.

5.Vulnerability Name: - SSL/TLS Recommended Cipher Suites

Severity: - Info

Plugin: - 156899

Port: - 443

Description: - The remote host has open SSL/TLS ports which advertise discouraged cipher suites. It is recommended to only enable support for the following cipher suites:

TLSv1.3:

- 0x13,0x01 TLS13_AES_128_GCM_SHA256
- 0x13,0x02 TLS13_AES_256_GCM_SHA384
- 0x13,0x03 TLS13_CHACHA20_POLY1305_SHA256

TLSv1.2:

- 0xC0,0x2B ECDHE-ECDSA-AES128-GCM-SHA256
- 0xC0,0x2F ECDHE-RSA-AES128-GCM-SHA256
- 0xC0,0x2C ECDHE-ECDSA-AES256-GCM-SHA384
- 0xC0,0x30 ECDHE-RSA-AES256-GCM-SHA384
- 0xCC,0xA9 ECDHE-ECDSA-CHACHA20-POLY1305
- 0xCC,0xA8 ECDHE-RSA-CHACHA20-POLY1305

This is the recommended configuration for the vast majority of services, as it is highly secure and compatible with nearly every client released in the last five (or more) years.

Solution: - Only enable support for recommened cipher suites.

Business Impact: - Data Security: If discouraged cipher suites remain enabled, encrypted traffic may be vulnerable to downgrade attacks or cryptographic weaknesses. This could allow attackers to intercept or decrypt sensitive information. Compliance Risk: Standards like PCI DSS, HIPAA, and NIST explicitly require strong encryption. Using weak or outdated ciphers can result in audit failures and potential fines.

6.Vulnerability Name: - Service Detection

severity: - Info

Plugin: - 22964

Port: - 80, 8080

Description: - Nessus was able to identify the remote service by its banner or by looking at the error message it sends when it receives an HTTP request.

Solution: - N/A

Business Impact: - The business impact is that attackers can map your environment more easily, so the recommended action is to minimize banner information, disable unnecessary services, and keep exposed services patched.

7.Vulnerability Name: - 39446 - Apache Tomcat Detection

Severity: - INFO

Plugin: - 39446

Port: - 80

Description: -Nessus was able to detect a remote Apache Tomcat web server.

Solution: - n/a

Business Impact: -Is an informational finding that identifies the presence of a remote Apache Tomcat web server. While this information itself does not indicate a security threat or impact on business operations, it can be useful for network administrators and security professionals to be aware of the technologies in use on their network. Understanding the presence of an Apache Tomcat server can be valuable for maintaining and securing web applications, but it does not require immediate action to mitigate a security risk**.**

8.Vulnerability Name: - Nessus SYN scanner

Severity: - Info

Plugin: - 11219

Port: - 80

Description: - This plugin is a SYN 'half-open' port scanner. It shall be reasonably quick even against a firewalled target.

Solution: - Protect your target with an IP filter.

Business Impact: - The business impact is that open ports revealed by such scans represent potential attack vectors, and organizations should minimize exposure and monitor for unauthorized scanning.

9.Vulnerability Name: - 45590 - Common Platform Enumeration (CPE)

Severity: - INFO

Plugin: - 45590

Port: - 0

Description: - By using information obtained from a Nessus scan, this plugin reports CPE (Common Platform Enumeration) matches for various hardware and software products found on a host.

Note that if an official CPE is not available for the product, this plugin computes the best possible CPE based on the information available from the scan.

Solution: - n/a

Business Impact: - This provides insights into hardware and software products identified on a host through a Nessus scan. It reports CPE matches, which are standardized identifiers for these products. This information is valuable for asset management and inventory purposes. While it doesn't signify a security threat, it aids administrators in understanding the components within their network, contributing to effective resource management and facilitating future system maintenance.

10.Vulnerability Name: - Nessus Scan Information

Severity: - Info

Plugin: - 19506

Port: - 0

Description: - This plugin displays, for each tested host, information about the scan itself:

- The version of the plugin set.
- The type of scanner (Nessus or Nessus Home).
- The version of the Nessus Engine.
- The port scanner(s) used.
- The port range scanned.
- The ping round trip time
- Whether credentialed or third-party patch management checks are possible.
- Whether the display of superseded patches is enabled
- The date of the scan.
- The duration of the scan.
- The number of hosts scanned in parallel.
- The number of checks done in parallel.

Solution: - N/A

Business Impact: - The business impact of this plugin is that it provides an audit trail and transparency into how the Nessus vulnerability scan was conducted. While it doesn't identify vulnerabilities itself, the information it records has several implications.

Stage 3

Report

Tittle: - This report covers the understanding and implementation of Security Operations Center (SOC) and Security Information and Event Management (SIEM) systems in a real-world college network environment. It explores how these systems work together with tools like IBM QRadar and MISP to detect, analyze, and respond to cyber threats in real time, complementing the Zero Trust Network Access (ZTNA) framework implemented using Zscaler.

➢ SOC — Security Operations Center

A Security Operations Center (SOC) is a centralized unit responsible for continuously monitoring, detecting, analyzing, and responding to cybersecurity incidents within an organization. It serves as the main command center where security professionals monitor networks, systems, and applications to protect them from cyber threats. The SOC team uses various security tools and technologies to collect and analyze security data from multiple sources. These sources include servers, firewalls, databases, applications, and network devices. The primary objective of a SOC is to identify potential threats at an early stage and respond quickly to prevent damage to the organization's information systems. SOC teams typically operate 24 hours a day and consist of different levels of analysts. Tier 1 analysts focus on monitoring alerts and identifying suspicious activities, Tier 2 analysts investigate alerts in detail to confirm whether they represent real security incidents, and Tier 3 analysts handle advanced threat investigations and threat hunting. In a college environment, a SOC can help protect systems such as student databases, examination portals, faculty portals, research data, and administrative systems from cyberattacks.

➢ SOC – cycle

The SOC operates through a continuous monitoring cycle that helps organizations detect and respond to threats effectively. The first stage of the SOC cycle is data collection, where security logs and events are collected from different systems across the network. These logs include information about user logins, network traffic, and system activities. The second stage is monitoring, where SOC analysts observe the incoming security events using monitoring tools. The third stage is threat detection, where suspicious patterns or abnormal activities are identified using security technologies. After detection, analysts begin the investigation stage to determine whether the alert represents a real cyber threat. If the threat is confirmed, the SOC team moves to the response stage, where appropriate actions such as blocking malicious IP addresses, isolating compromised systems, or updating firewall rules are taken. Finally, the recovery and reporting stage ensures that systems are restored to normal operation and lessons are documented to prevent similar incidents in the future.

➢ SIEM

Security Information and Event Management (SIEM) is a cybersecurity technology used to collect, store, analyze, and monitor security data generated from different systems within an organization. SIEM solutions combine two important capabilities known as Security Information Management (SIM) and Security Event Management (SEM). SIM focuses on storing and analyzing log data collected from multiple devices, while SEM focuses on monitoring security events in real time and generating alerts when suspicious activity is detected. SIEM tools gather logs from various sources such as firewalls, servers, applications, operating systems, network devices, and user authentication systems. By analyzing these logs, SIEM systems can identify patterns that indicate possible cyberattacks. For example, repeated failed login attempts, unusual access to sensitive files, or abnormal network traffic may indicate a security breach. SIEM solutions help organizations improve their security visibility and enable faster detection and response to cyber threats.

➢ SIEM CYCLE

The SIEM system follows a structured process to analyze security data and detect threats. The first step in the SIEM cycle is log collection, where logs from multiple devices and applications are gathered into a centralized system. The second step is log normalization, where the collected logs are converted into a standard format to ensure they can be analyzed efficiently. The third stage is event correlation, where the SIEM system analyzes multiple events together to identify suspicious patterns. For example, if a user logs in from an unusual location and attempts to access sensitive data, the SIEM system may recognize this as a potential threat. The next stage is alert generation, where the system automatically generates alerts when suspicious activities are detected. Security analysts then investigate these alerts to determine their severity and whether they represent real attacks. If a threat is confirmed, the organization initiates an incident response process to contain and eliminate the threat.

➢ MISP

Malware Information Sharing Platform (MISP) is an open-source threat intelligence platform used by organizations to share information about cybersecurity threats. It allows security teams to exchange data related to malware, malicious IP addresses, phishing domains, and attack techniques. By sharing threat intelligence through MISP, organizations can improve their ability to detect and respond to cyber threats quickly. For example, if one organization identifies a phishing website targeting users, the information can be shared through MISP so that other organizations can block the same domain before it affects their users. MISP helps improve collaboration between cybersecurity teams and strengthens overall security defenses by enabling faster threat detection and response.

➢ Your college network information

A typical college network consists of multiple interconnected systems that support academic and administrative activities. These systems include student information systems, examination management systems, learning management platforms, library databases, research servers, and administrative applications. Thousands of students, faculty members, and staff access these systems every day through campus networks and wireless internet connections. Because of this large number of users and devices, college networks can become potential targets for cyberattacks. Attackers may

attempt to steal sensitive information, manipulate academic records, or disrupt online services. Implementing security technologies such as SOC and SIEM can help colleges monitor network activity, detect suspicious behavior, and protect critical systems from potential cyber threats.

- **How you think you deploy soc in your college**

  To deploy a Security Operations Center in a college environment, the institution must first ensure that all critical systems generate and send security logs to a centralized monitoring platform. A SIEM solution such as IBM QRadar can be implemented to collect and analyze logs from various network components including servers, firewalls, applications, and network devices. In addition to SIEM, modern security models such as Zero Trust Network Access (ZTNA) can be implemented using platforms like Zscaler. ZTNA ensures that users are granted access only to specific applications after proper authentication and authorization. This approach prevents direct exposure of internal networks and significantly reduces the risk of unauthorized access. By combining SOC monitoring, SIEM analytics, and Zero Trust architecture, colleges can significantly strengthen their cybersecurity posture**.**

- **Threat intelligence**

  Threat intelligence refers to the collection and analysis of information related to current and potential cyber threats. It provides security teams with valuable insights about malicious actors, attack techniques, and vulnerabilities that may affect their systems. Threat intelligence data may include malicious IP addresses, malware signatures, phishing domains, and known attack patterns. Organizations gather threat intelligence from multiple sources such as cybersecurity vendors, government agencies, research communities, and threat intelligence platforms like MISP. When integrated with SIEM systems, threat intelligence helps automatically detect known threats and alert security teams in real time.

- **Incident response**

  Incident response is the structured process used by organizations to detect, analyze, and respond to cybersecurity incidents. The first phase is preparation, where organizations establish policies, tools, and procedures for handling security incidents. The second phase is detection, where monitoring systems identify suspicious activities that may indicate an attack. The third phase is analysis, where security experts evaluate the severity and impact of the incident. Once the threat is confirmed, containment measures are taken to prevent the attack from spreading to other systems. After containment, the eradication phase involves removing malware or vulnerabilities from affected systems. The recovery phase ensures that systems are restored to normal operation. Finally, organizations conduct a lessons-learned review to improve their security strategies and prevent similar incidents in the future.

- **Qradar & understanding about tool**

  IBM QRadar is a powerful Security Information and Event Management platform widely used in cybersecurity operations. It collects and analyzes security data from across the organization's network and presents it through a centralized dashboard. QRadar helps security analysts detect threats in real time by correlating events and identifying suspicious patterns. The platform provides features such as

log management, event correlation, threat detection, incident investigation, and risk prioritization. QRadar dashboards display important information including top security offenses, network activity, suspicious user behavior, and vulnerability data. These insights help security teams quickly identify potential threats and take appropriate actions to protect the organization's systems.

Conclusion: -

Stage 1: - Web application testing

From Stage 1, we gained a deep understanding of web application vulnerability testing using the OWASP Top 10 framework as our guide. We learned that web applications contain a wide range of vulnerabilities — from broken access control and cryptographic failures to injection flaws and improper authentication. By testing both the practice website (itsecgames.com / bWAPP) and the main college website (vtop.vit.ac.in), we saw firsthand how real-world applications carry these vulnerabilities and how relatively simple tools can identify them. The most important lesson was that web application security is not optional — every single vulnerability we found could be exploited by an attacker to steal data, disrupt services, or take control of systems. The OWASP Top 10 framework gave us a systematic, industry-recognized approach to identifying and prioritizing these risks.

Stage 2: - Nessus Vulnerability Scanner

Stage 2 introduced us to the power of automated vulnerability scanning through the Nessus tool. Unlike Stage 1 where we manually tested specific vulnerabilities, Nessus automatically scanned the target website testfire.net and produced a comprehensive report of all identified security weaknesses within minutes. We discovered 10 vulnerabilities ranging from medium-severity TLS protocol issues to informational findings about server configuration. The most significant finding was that the website still supports TLS 1.0 and TLS 1.1 — outdated protocols that have known cryptographic weaknesses. We also found that HSTS was not configured, leaving users vulnerable to SSL stripping attacks. The key understanding from Stage 2 is that automated scanning tools like Nessus are essential for organizations because no human team can manually check thousands of servers for hundreds of vulnerability types — automation is necessary to maintain security at scale.

Stage3: - What you understand from SOC / SEIM / Qradar Dashboard.

Future Scope: - Future of web application testing

The future of WAT is bright, as web applications become increasingly complex and sophisticated. Organizations are increasingly reliant on web applications to conduct business, and they need to be confident that their web applications are secure and

reliable.
Here are some of the key trends that are expected to shape the future of WAT:

- Increased focus on security: Security is a top priority for all organizations, and WAT is essential for identifying and mitigating security vulnerabilities. In the future, we can expect to see even more emphasis on security testing, as web applications become increasingly targeted by cyberattacks.
- Rise of artificial intelligence (AI) and machine learning (ML): AI and ML are already being used in WAT, and their role is expected to grow in the future. AI and ML can be used to automate repetitive tasks, such as test case generation and execution. They can also be used to identify complex patterns and anomalies that may be difficult to detect with traditional testing methods.
- Shift to cloud-based testing: More and more organizations are moving their web applications to the cloud. This trend is driving the growth of cloud-based WAT platforms. Cloud-based testing platforms offer a number of advantages, such as scalability, flexibility, and cost-effectiveness.
- Increased focus on user experience (UX) testing: UX testing is essential for ensuring that web applications are easy to use and meet the needs of users. In the future, we can expect to see more focus on UX testing, as organizations increasingly recognize the importance of providing a positive user experience.

Future scope of the testing process:-

The future scope of the testing process is bright, as software becomes increasingly complex and sophisticated. Organisations are increasingly reliant on software to conduct business, and they need to be confident that their software is high-quality and reliable.

Here are some of the key trends that are expected to shape the future of the testing process:

- Increased focus on continuous testing: Continuous testing is a methodology that involves testing software throughout the SDLC, from development to deployment. This helps to identify defects early and prevent them from causing problems later in the development process.
- Rise of AI and ML: AI and ML are already being used in the testing process, and their

role is expected to grow in the future. AI and ML can be used to automate repetitive tasks, such as test case generation and execution. They can also be used to identify complex patterns and anomalies that may be difficult to detect with traditional testing methods.

- Shift to cloud-based testing: Cloud-based testing platforms offer a number of advantages, such as scalability, flexibility, and cost-effectiveness. This is driving the growth of cloud-based testing platforms.
- Increased focus on testing automation: Testing automation is the use of software to execute test cases without human intervention. Testing automation can help to save time and resources, and it can also help to improve the quality and efficiency of testing.

Future scope of SOC / SEIM: -

The future scope of Zero Trust Network Access (ZTNA) and the broader Zero Trust framework is poised for significant evolution, driven by emerging technologies and changing threat landscapes:

1. **AI-Driven Zero Trust (AI-ZTA):** Future Zero Trust implementations will leverage advanced AI and deep learning to move beyond static policies. Systems will continuously learn user behavior, predict anomalous activities before they occur, and dynamically adjust access privileges in real-time based on contextual risk, creating a truly "adaptive" security posture.
2. **Integration with Edge Computing and IoT:** As organizations deploy more IoT devices and edge computing nodes, Zero Trust principles will extend to these resource-constrained environments. Expect the development of lightweight Zero Trust agents and protocols that can authenticate and secure machine-to-machine (M2M) communication at the edge, preventing large-scale botnet attacks.
3. **Identity-Centric Everything:** The future will see identity become the ultimate security perimeter. Zero Trust will evolve to incorporate advanced identity verification methods, including **continuous behavioral biometrics** (keystroke dynamics, gait analysis)
   and **decentralized identity** solutions using blockchain, ensuring that the user behind the session is verified at all times.
4. **Convergence with SASE Architecture:** Zero Trust will be a core component of the Secure Access Service Edge (SASE) framework. This convergence will provide

organizations with a unified, cloud-delivered stack that combines ZTNA, Secure Web Gateways (SWG), Cloud Access Security Brokers (CASB), and Firewall-as-a-Service (FWaaS), simplifying management and ensuring consistent security for all users, regardless of location.

Topics explored: - OWASP Top 10 Framework, Zero Trust Network Access, Zscaler Private Access (ZPA)
Tools explored: - Kali Linux, OWASP ZAP, SSL Labs (SSLTest), SecurityHeaders.com, Nessus Essentials

--------THE END -------